Screaming about detection coverage in ALLCAPS

BSides Philly 2025

Speaker

Evan Perotti
@2xxeformyshirt
2xxe.com

Lead Scientist
Security Risk Advisors
sra.io

Agenda

Motivations

Atomic Testing

Attack Behaviors

Implementations

Results

Caveats

- Presented from a purple team perspective
- “Purple” teams vs purple teams

Motivation

$TOOL detected/blocked $ATTACK

↓

Did it actually?

Motivation

- Do a lot of purple teams for clients
- See all manner of blocks/detects
- Some very bad block/detect criteria

Motivation

- Blocks/detections looking for…
  - exact command lines
  - exact arguments
  - implementation-specific indicators
- Detection “doesn’t count” conversations
- Needed a way to demonstrate the issues practically
- Created *ALLCAPS*

Atomicity

Atomic Testing

- Atomic testing
- Evaluate controls against specific behavior in isolation
- Minimize impact from related behaviors
- Cover breadth of behaviors, variations

Approaches

- Frameworks like Atomic Red Team
- BAS
- Fully manual
- Custom tooling
- Many approaches rely on native utilities

ALLCAPS

- https://github.com/SecurityRiskAdvisors/ALLCAPS
- Open-source tool for managing “capabilities”, payload generation
- Isolate behaviors as individual payloads
- Helps realize atomic approach, minimize conflation

Example

Registry Credential Dumping

```
reg.exe save HKLM\SAM
```

Example

Registry dumping capability

```
1 HKEY hKey;
2
3 {{ WINAPI("RegOpenKeyExW") }}({{ hive }}, L"{{ path }}", 0, KEY_READ, &hKey);
4 {{ WINAPI("RegSaveKeyExW") }}(hKey, L"{{ outfile }}", NULL, REG_LATEST_FORMAT);
5 {{ WINAPI("RegCloseKey") }}(hKey);
```

Example

The payload config

Enable privilege →

Dump SYSTEM →

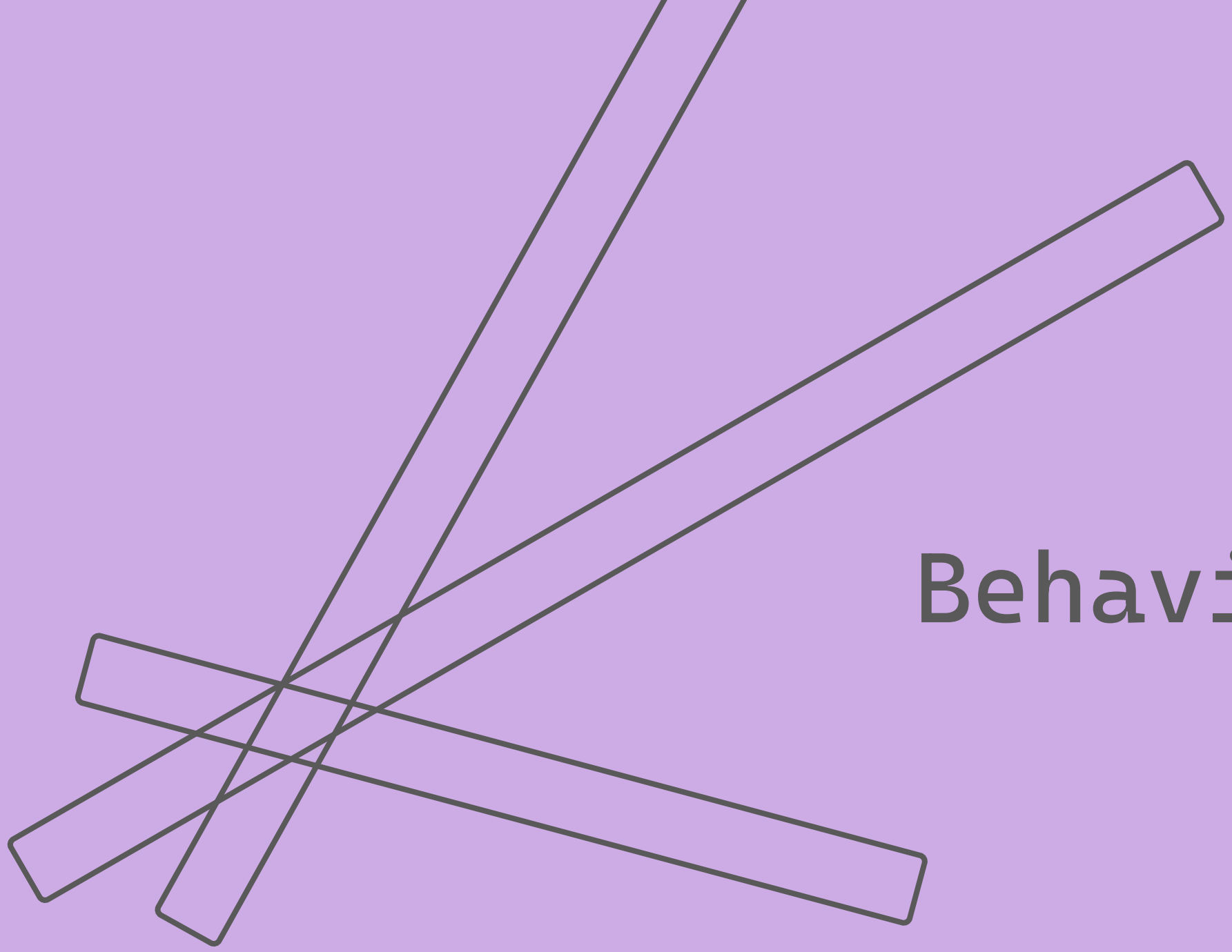
Dump SAM →

```yaml
outfile: regcreddump.exe

capabilities:
  directory: capabilities
  desired:
  - enableprivilege:
      privilege: SeBackupPrivilege
  - regsave:
      hive: HKEY_LOCAL_MACHINE
      path: SYSTEM
      outfile: system.hive
  - regsave:
      hive: HKEY_LOCAL_MACHINE
      path: SAM
      outfile: sam.hive

constraints:
  language: c
  format: exe
  architecture: x64
```

Example

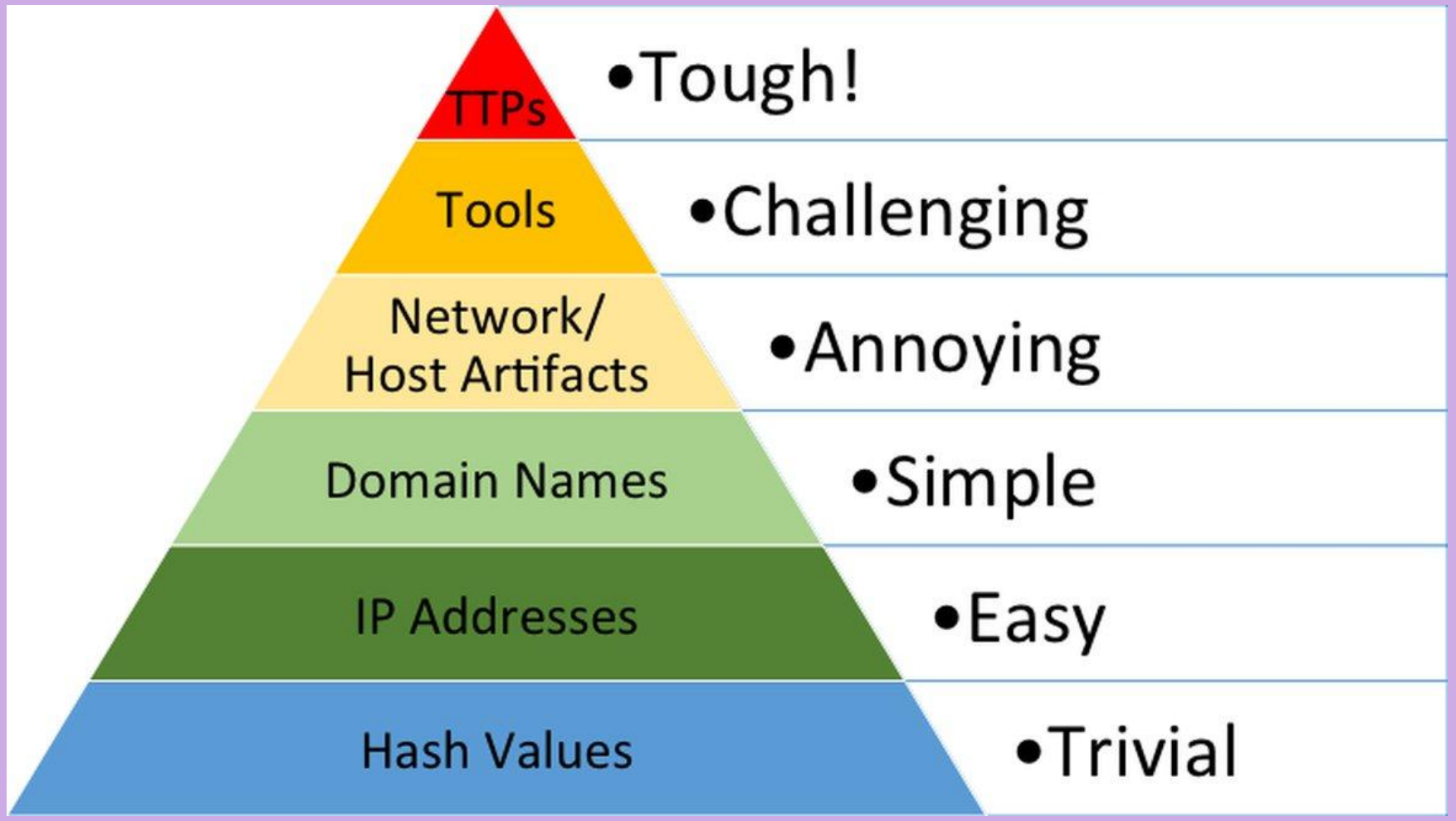
approximately reg.exe save …

```
C:\Users\User\Documents\demo>dir
 Volume in drive C is Windows
 Volume Serial Number is 7422-F0C6

 Directory of C:\Users\User\Documents\demo

                    <DIR>          .
                    <DIR>          ..
                          131,064 regcreddump.exe
                           98,304 sam.hive
                       13,430,784 system.hive
               3 File(s)     13,660,152 bytes
               2 Dir(s)  64,066,699,264 bytes free
```

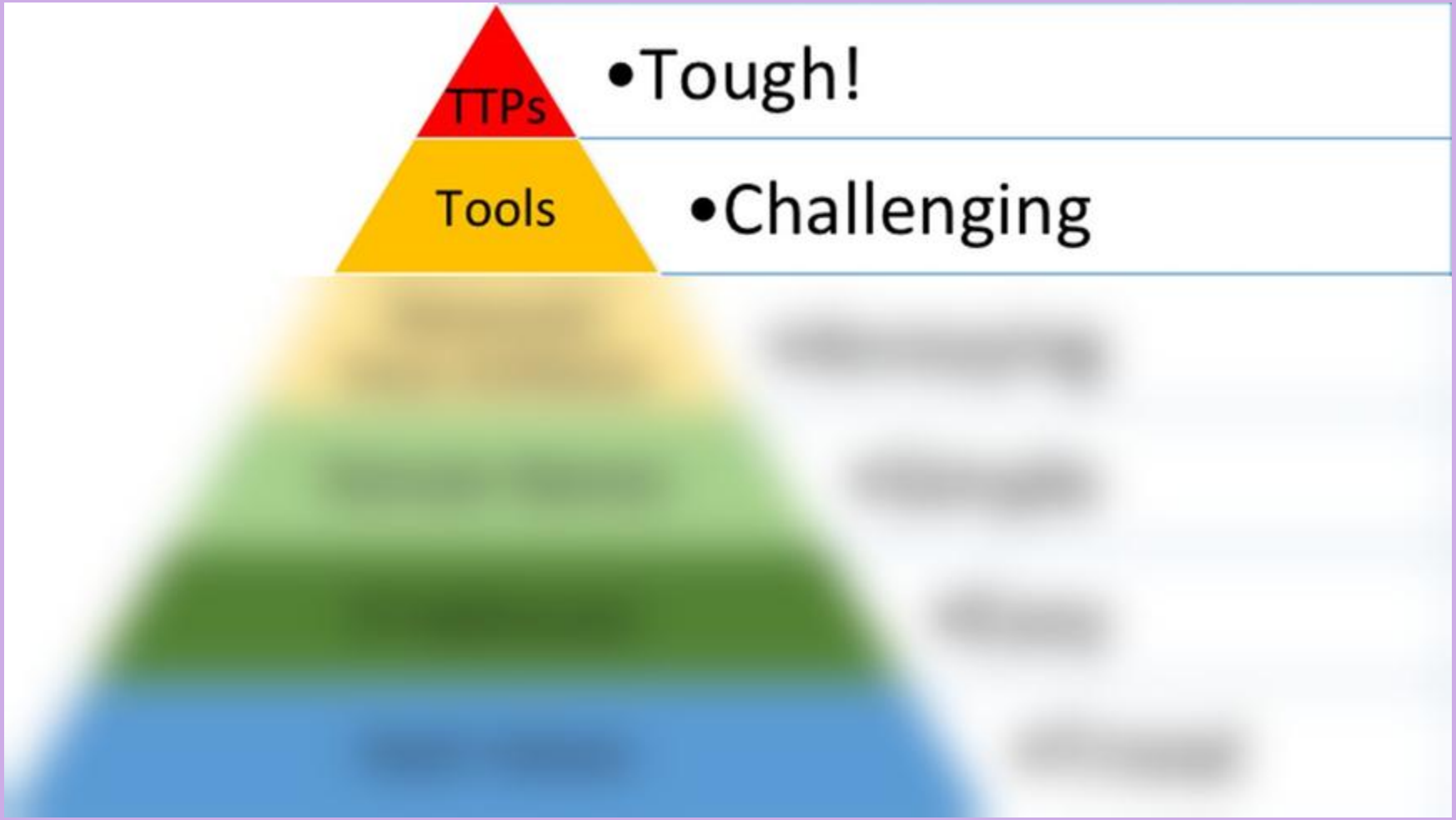


Behaviors

Pyramid of Pain

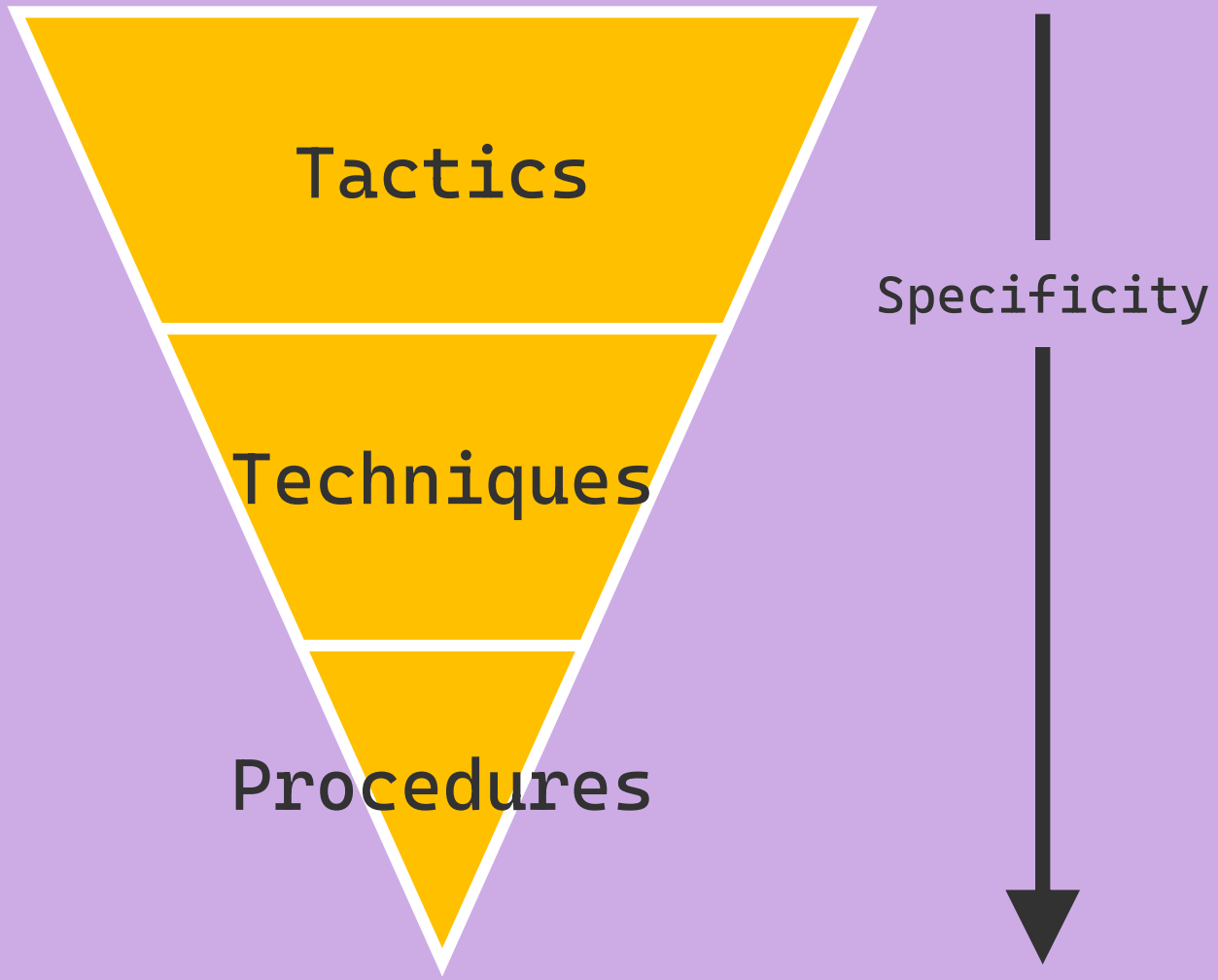


Pyramid of Pain



TTPs

TTPs
•Tough!
Tools
•Challenging

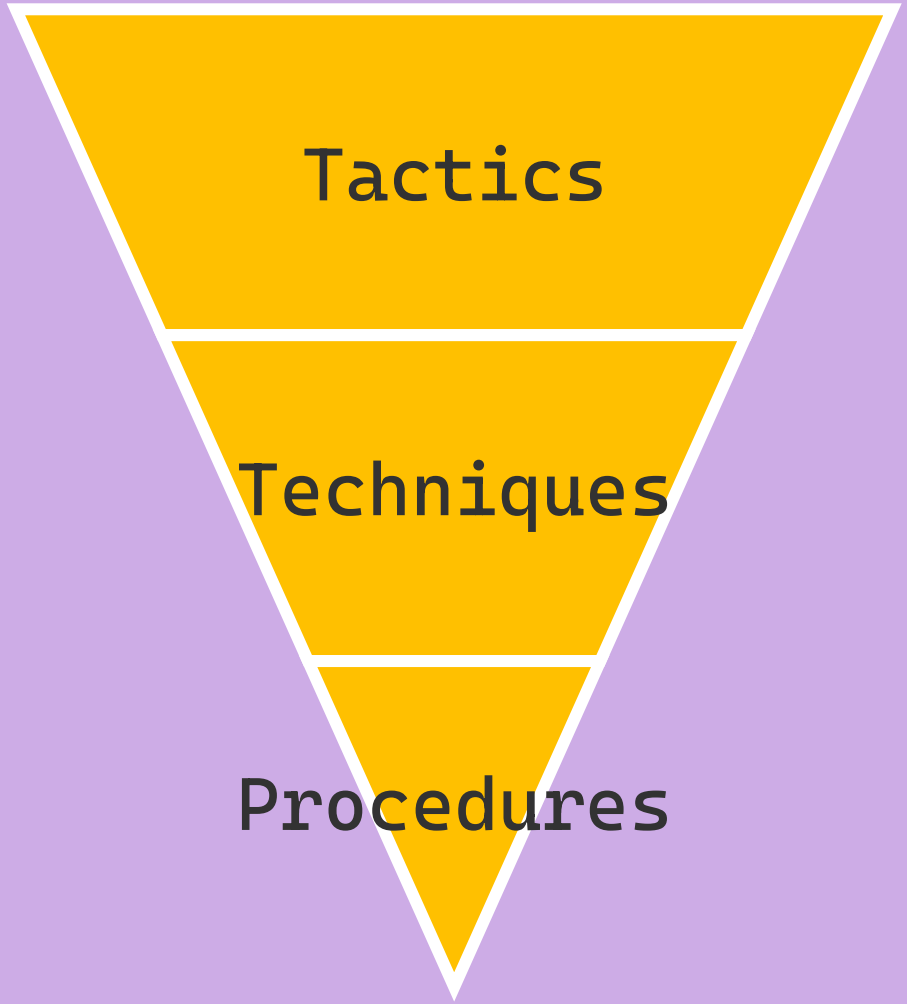

Tactics
Techniques
Procedures
Specificity

TTPs

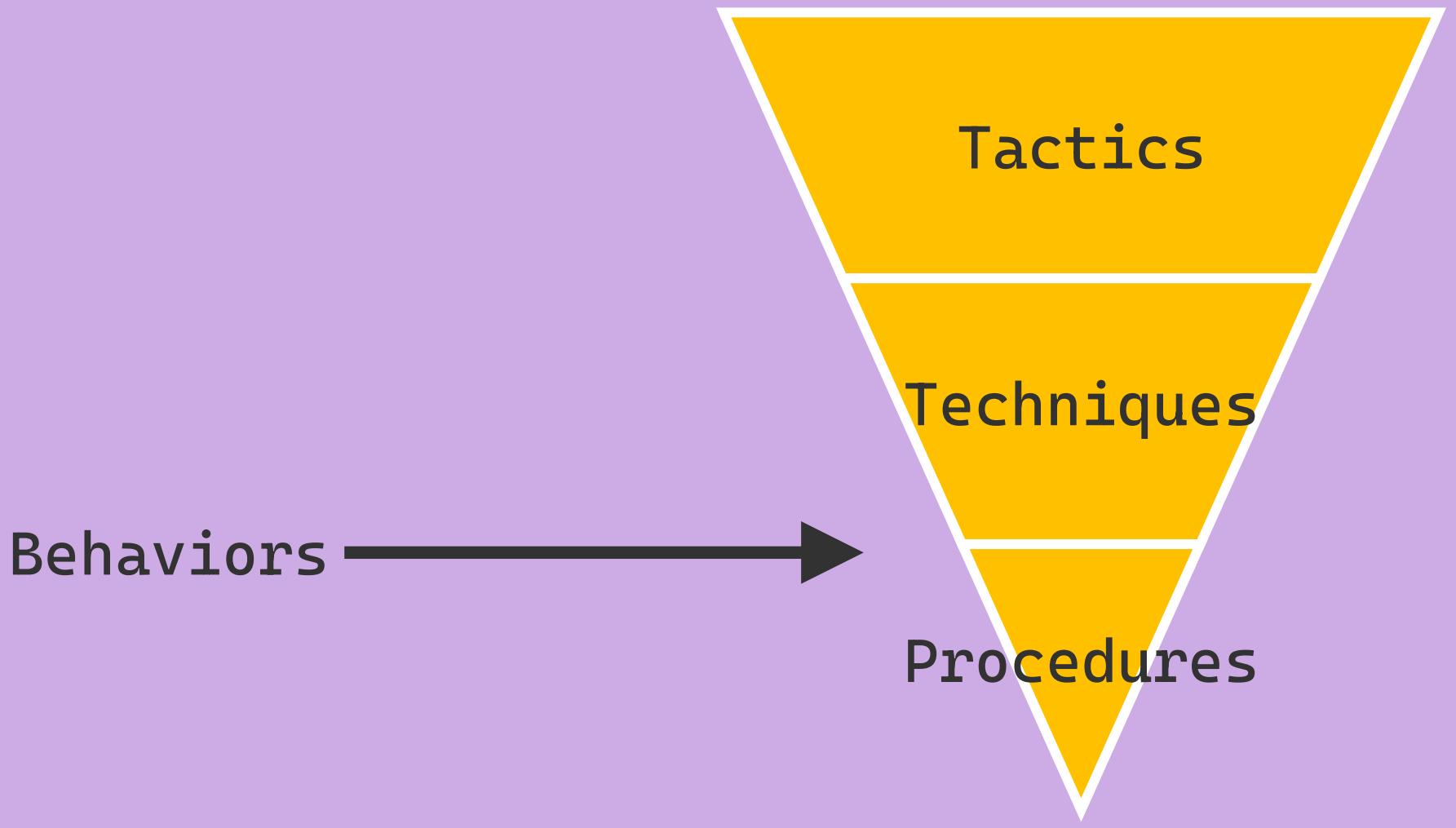
Key Concepts

ATT&CK is a model that attempts to systematically categorize adversary behavior. The main components of the model are:

- **Tactics**, represents "why" or the reason an adversary is performing an action
- **Techniques**, represents "how" adversaries achieve tactical goals by performing an action
- **Sub-techniques**, a more specific or lower-level description of adversarial behavior
- **Procedures**, specific implementation or in-the-wild use the adversary uses for techniques or sub-techniques



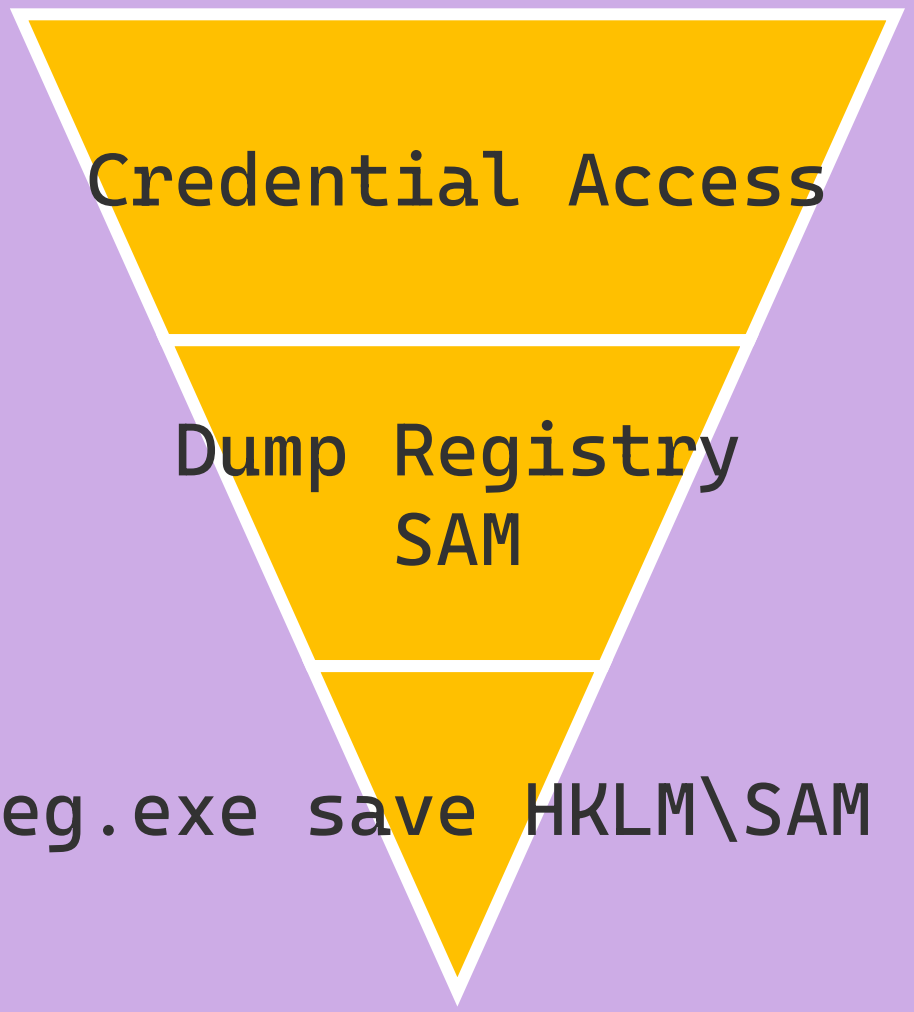
Behaviors



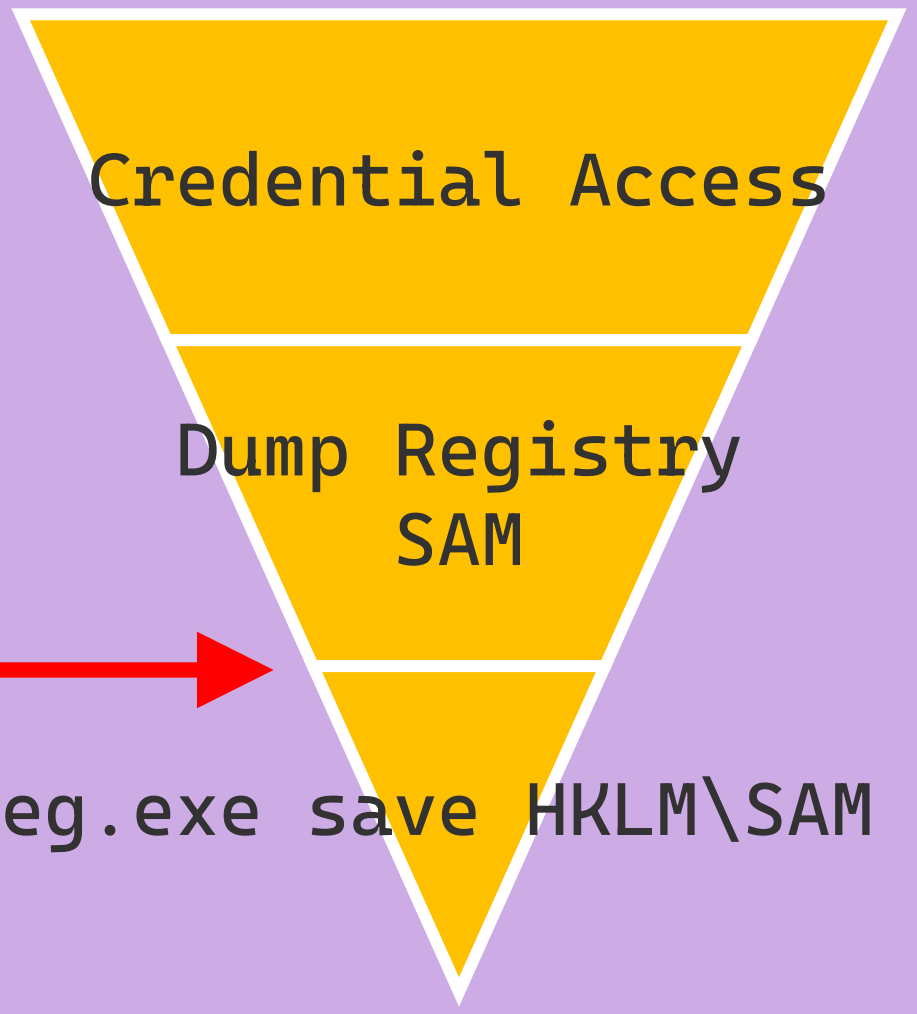
Example

TA0006 →

T1003.002 →



Example



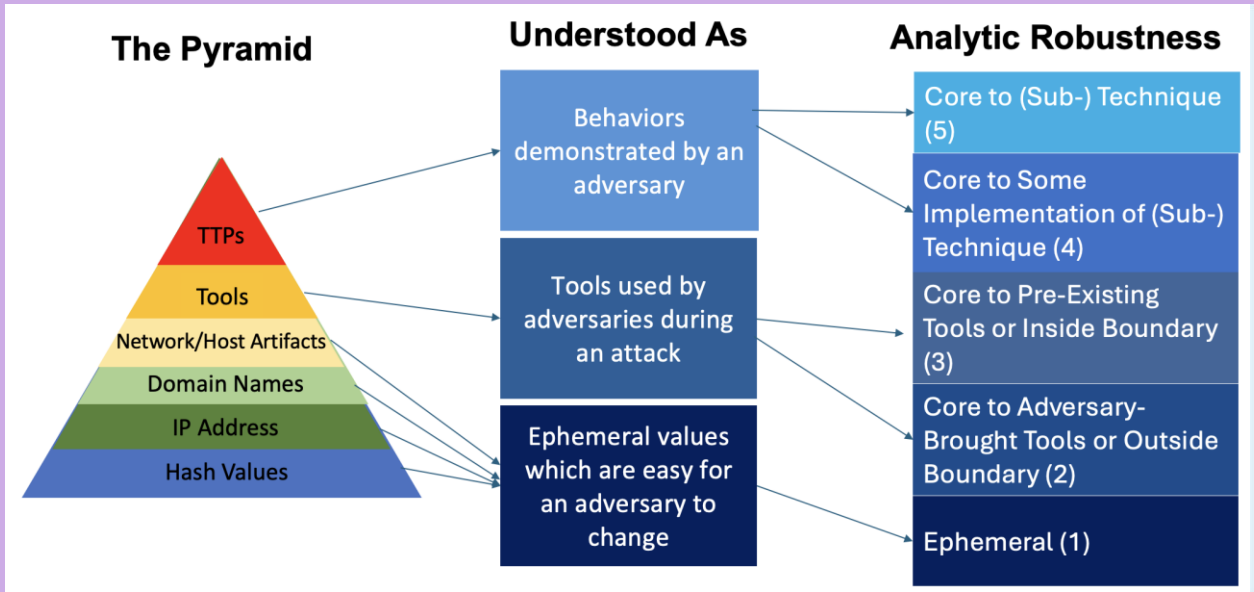
Open Registry
+ dump hive

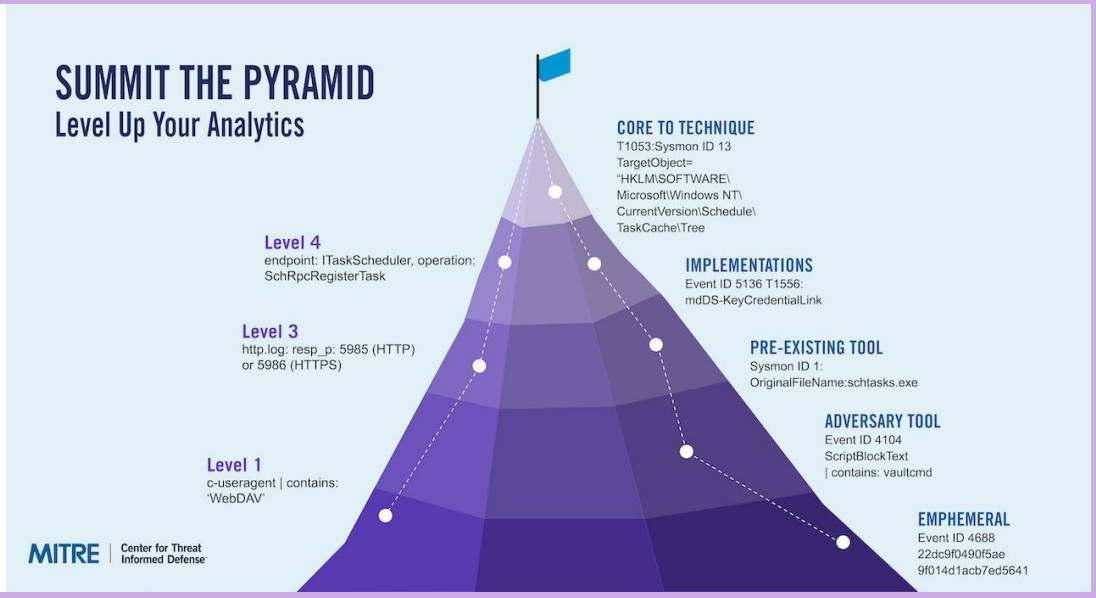
Behaviors

- Ideally, want to block/detect behaviors
- Gives exposure to more variations
- ALLCAPS helps focus on these behaviors

Side note

- “Summiting the Pyramid” by MITRE’s CTID
  - https://center-for-threat-informed-defense.github.io/summiting-the-pyramid/
- Defines a methodology for assessing detections





Implementations

Tools

- Goal: Dump registry

- Methods
  - reg.exe save HKLM\SAM
  - mimikatz lsadump::sam
  - impacket’s secretsdump.py (local)
  - <custom tool>
  - …

Detections

```yaml
logsource:
    category: process_creation
    product: windows
detection:
    selection_img:
        - Image|endswith: '\reg.exe'
        - OriginalFileName: 'reg.exe'
    selection_cli_flag:
        CommandLine|contains:
            - ' save '
            - ' export '
            - ' ˢave '
            - ' eˣport '
    selection_cli_hklm:
        CommandLine|contains:
            - 'hklm'
            - 'hkʟm'
            - 'hkey_local_machine'
            - 'hkey_ʟocal_machine'
            - 'hkey_locaʟ_machine'
            - 'hkey_ʟocaʟ_machine'
    selection_cli_hive:
        CommandLine|contains:
            - '\system'
            - '\sam'
            - '\security'
            - '\ˢystem'
```

```yaml
logsource:
    category: process_creation
    product: windows
detection:
    selection_reg:
        CommandLine|contains: ' save
    selection_key:
        CommandLine|contains:
            - HKLM\sam
            - HKLM\system
            - HKLM\security
    condition: all of selection_*
```

```yaml
logsource:
    product: windows
detection:
    keywords:
        - 'dpapi::masterkey'
        - 'eo.oe.kiwi'
        - 'event::clear'
        - 'event::drop'
        - 'gentilkiwi.com'
        - 'kerberos::golden'
        - 'kerberos::ptc'
        - 'kerberos::ptt'
        - 'kerberos::tgt'
        - 'Kiwi Legit Printer'
        - 'lsadump::'
        - 'mimidrv.sys'
        - '\mimilib.dll'
        - 'misc::printnightmare'
        - 'misc::shadowcopies'
        - 'misc::skeleton'
        - 'privilege::backup'
        - 'privilege::debug'
        - 'privilege::driver'
        - 'sekurlsa::'
    filter:
        EventID: 15  # Sysmon's FileStrea
    condition: keywords and not filter
```

```yaml
detection:
    selection:
        - TargetFilename|endswith:
            - '\Temp\sam'
            - '\sam.sav'
            - '\Intel\sam'
            - '\sam.hive'
            - '\Perflogs\sam'
            - '\ProgramData\sam'
            - '\Users\Public\sam'
            - '\AppData\Local\sam'
            - '\AppData\Roaming\sam'
            - '_ShadowSteal.zip'
            - '\Documents\SAM.export'
            - ':\sam'
        - TargetFilename|contains:
            - '\hive_sam_'
            - '\sam.save'
            - '\sam.export'
            - '\~reg_sam.save'
            - '\sam_backup'
            - '\sam.bck'
            - '\sam.backup'
    condition: selection
```

Robustness

- Bad detections aren’t free!
- Cost time, processing power
- Create a false sense of security

Example

Process-based detections

Failure modes

- Failure mode: argument order
- **command.exe /foo /bar == command.exe /bar /foo**
- but “/foo*/bar” ≠ “/bar*/foo”

Failure modes

- Failure mode: process name
- Image vs File name vs command line
  - renamed net.exe
  - net.exe vs net1.exe
- Image not always reliable either
  - https://undev.ninja/sysmon-image-file-name-evasion/

Failure modes

- Failure mode: supplied arguments
- /foo vs -foo
- Optional /foo

Robustness

- $SignaturesAreDead = “Long Live RESILIENT Signatures” wide ascii nocase
  - talk by Daniel Bohannon + Matthew Dunwoody
  - https://www.youtube.com/watch?v=YGJaj6_3dGA
- Where possible, address at a lower-level

Telemetry

Event ID 12: RegistryEvent (Object create and delete)

Registry key and value create and delete operations map to this event type, which can be useful for monitoring for changes to Registry autostart locations, or specific malware registry modifications.

Sysmon uses abbreviated versions of Registry root key names, with the following mappings:

← Sysmon

Audit Registry

Audit Registry allows you to audit attempts to access registry objects. A security audit event is generated only for objects that have system access control lists (SACLs) specified, and only if the type of access requested, such as Read, Write, or Modify, and the account making the request match the settings in the SACL.

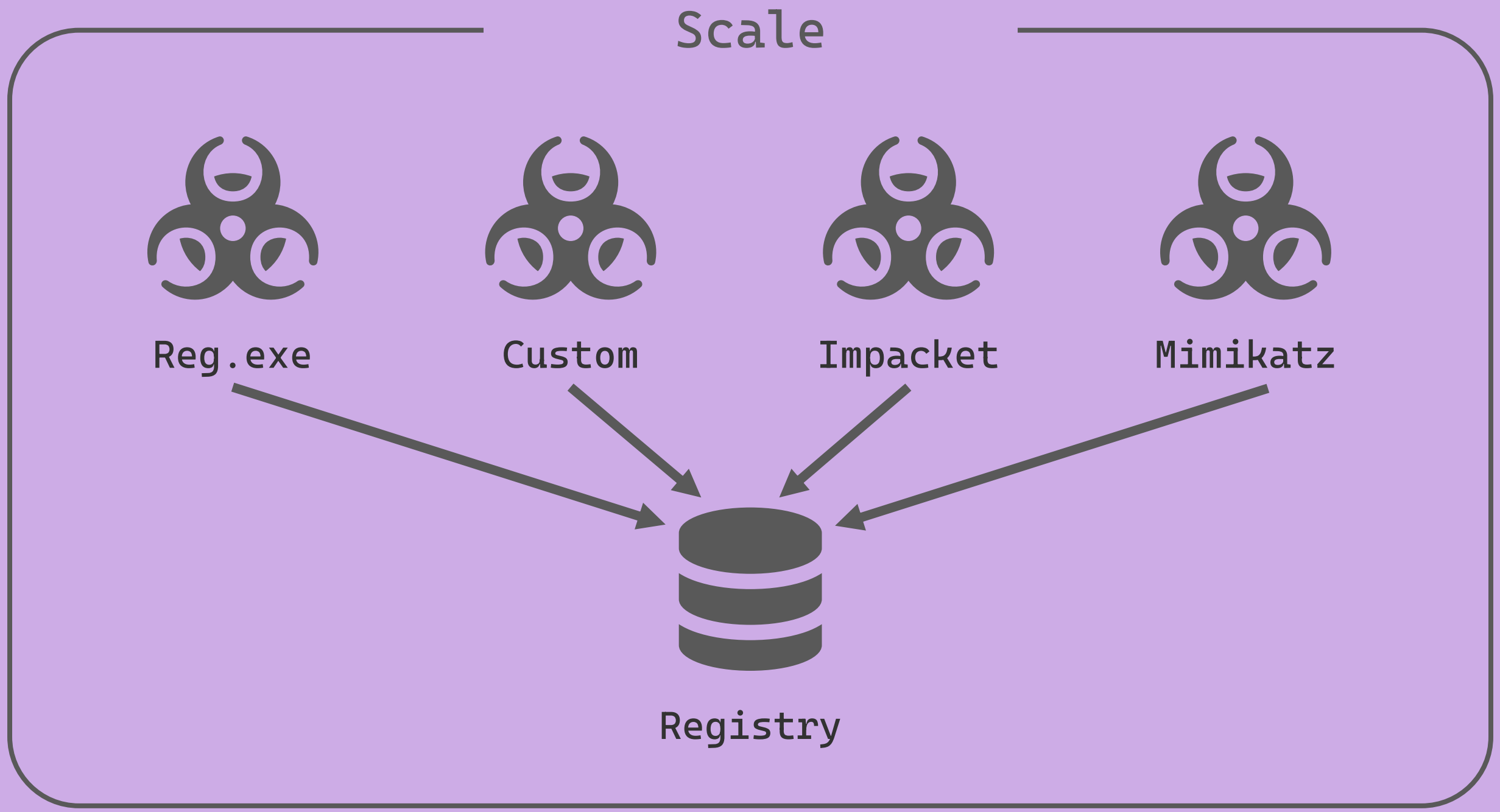
Advanced Audit →

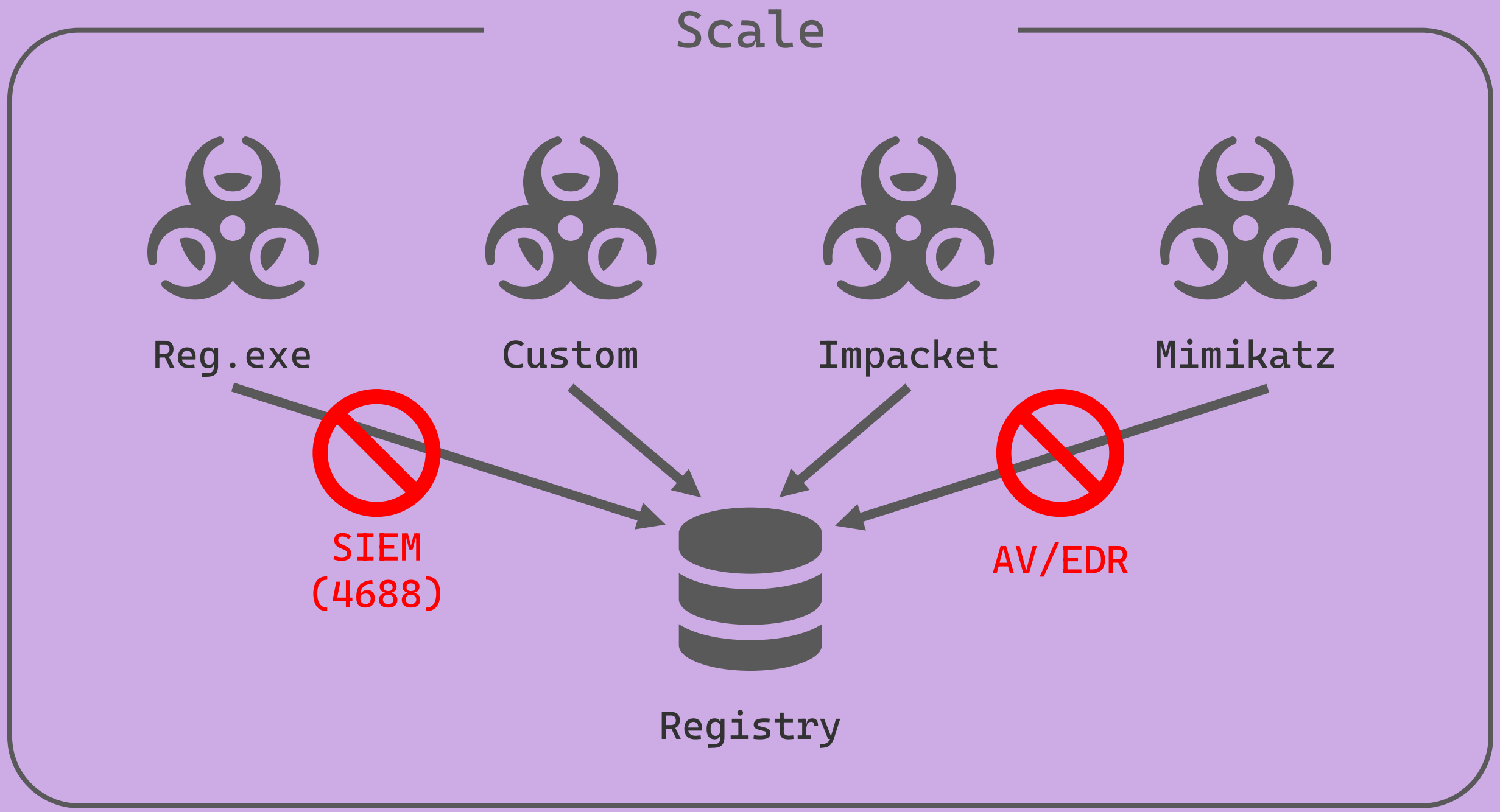
DeviceRegistryEvents

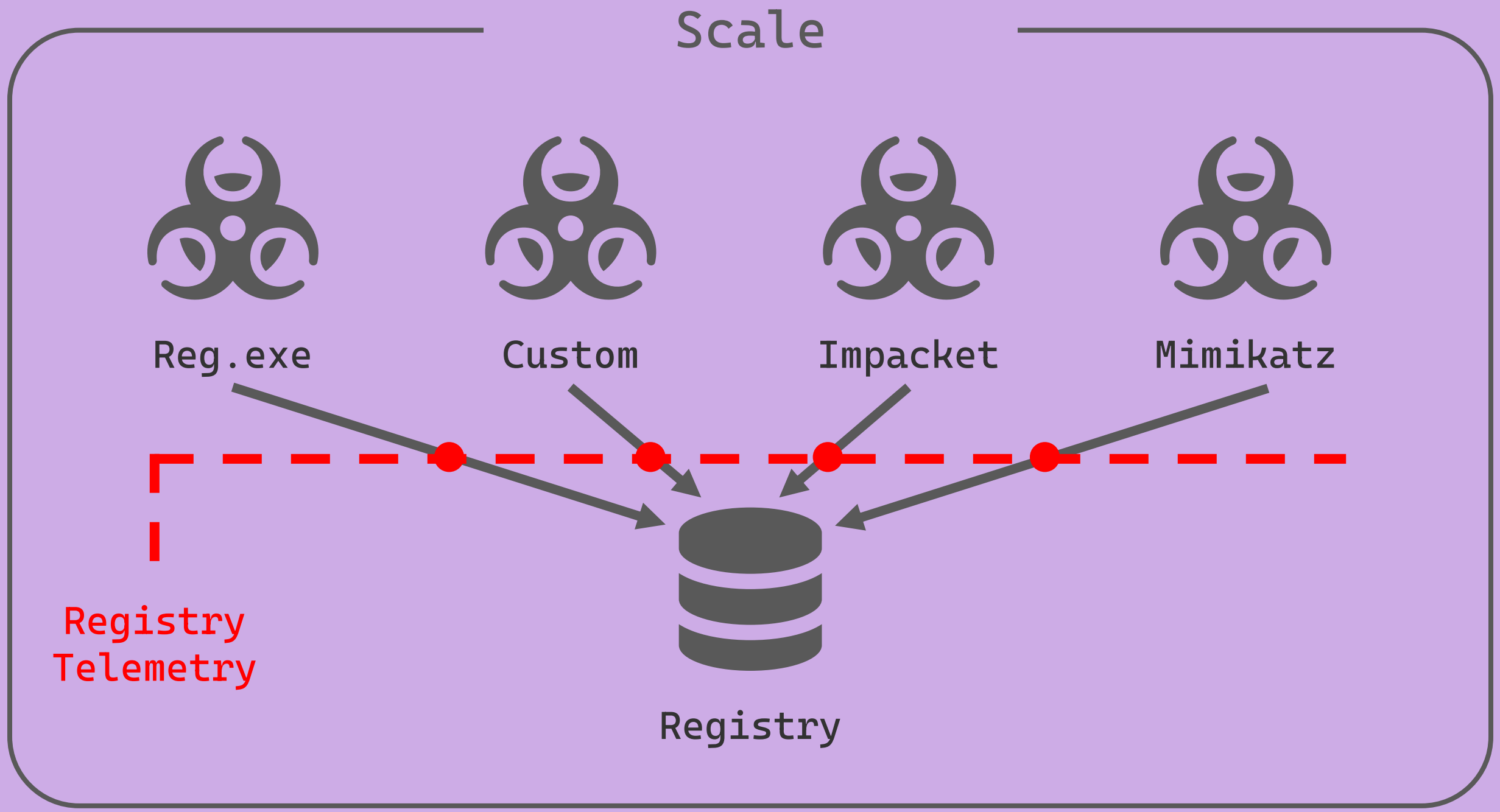
Applies to: Microsoft Defender XDR, Microsoft Sentinel in the Microsoft Defender portal

The `DeviceRegistryEvents` table in the advanced hunting schema contains information about the creation and modification of registry entries. Use this reference to construct queries that return information from this table.

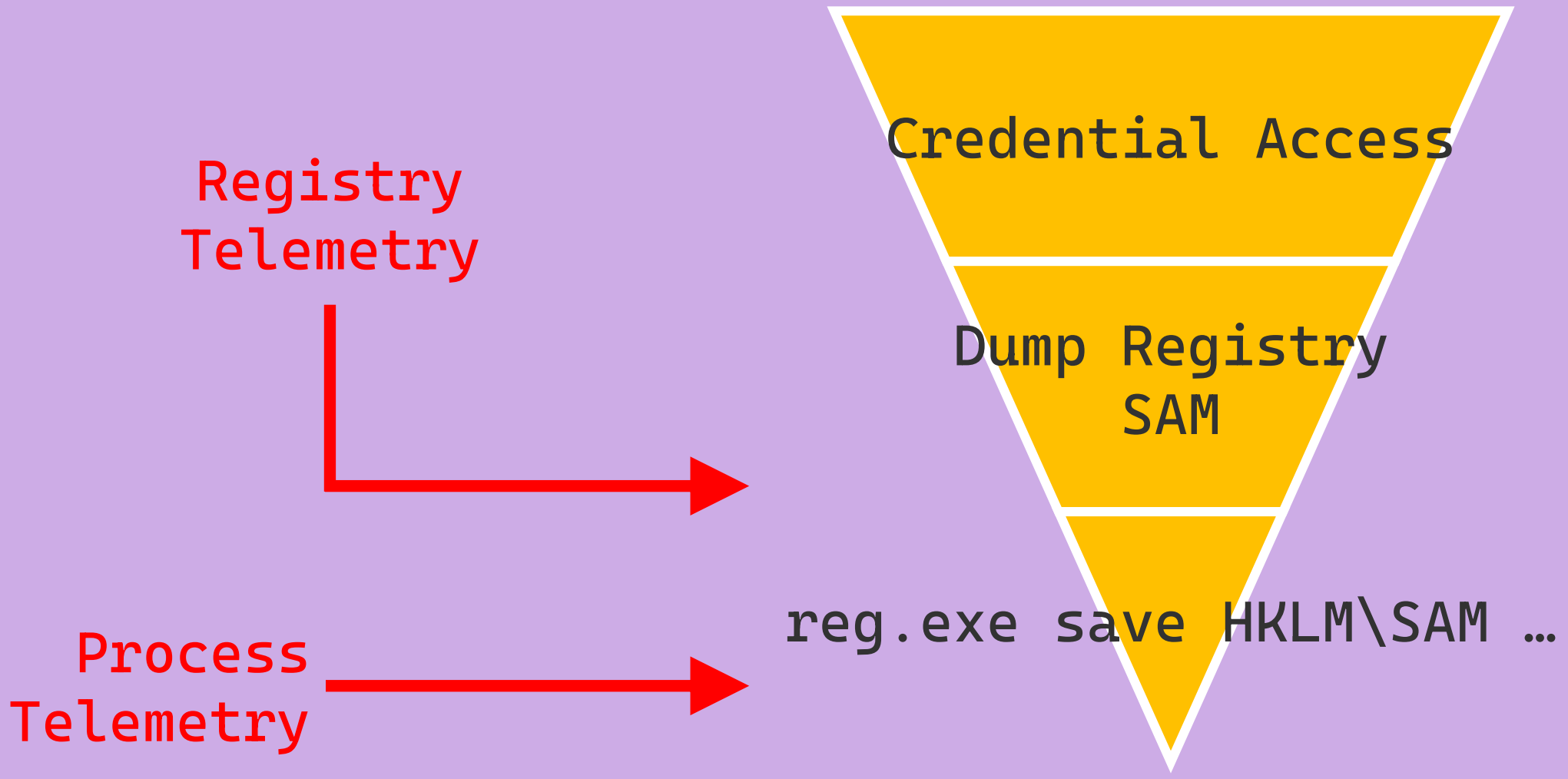
← DFE


Scale
Reg.exe
Custom
Impacket
Mimikatz
Registry


Scale
Reg.exe
Custom
Impacket
Mimikatz
SIEM
(4688)
AV/EDR
Registry


Scale
Reg.exe
Custom
Impacket
Mimikatz
Registry
Telemetry
Registry

Attack Telemetry



Defense Tools

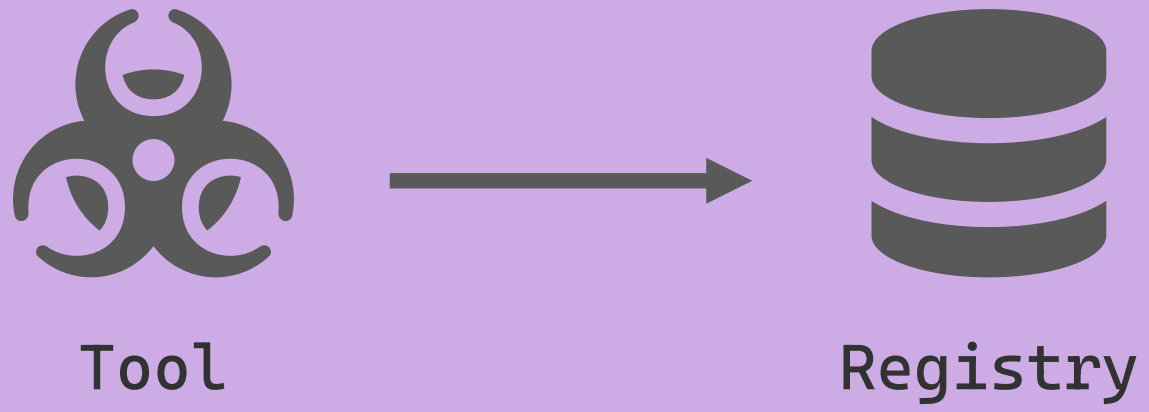
- But we can’t control our tools!
- If $EDR cares about $PROCESS → no telemetry
- ALLCAPS helps here
  - Avoid reputational baggage of LOLBins
  - Side-step issues with process detections

Side note

- “Capability Abstraction” by SpecterOps
  - https://posts.specterops.io/capability-abstraction-fbeaeeb26384
- Define a way of evaluating attacks at API layer

T1208 - Kerberoasting				
Tool	PowerShell Invoke-Kerberoast	Rubeus kerberoast	Mimikatz kerberos::ask	Rubeus asktgs
Managed Code	.NET KerberosRequestorSecurityToken			
Windows API Function	InitializeSecurityContext		LsaCallAuthenticationPackage	
RPC	4f32adc8-6052-4a04-8701-293ccf2096f0 C:\WINDOWS\SYSTEM32\SspiSrv.dll			
Network Protocol	Kerberos TGS-REQ/REP			

Outcomes



"Did we detect/block $ATTACK?"

- Blocked download of tool → Nope!
- Blocked tool on write → Nope!
- Blocked tool on execute → Nope!
- Blocked tool access → Yep!

Layers

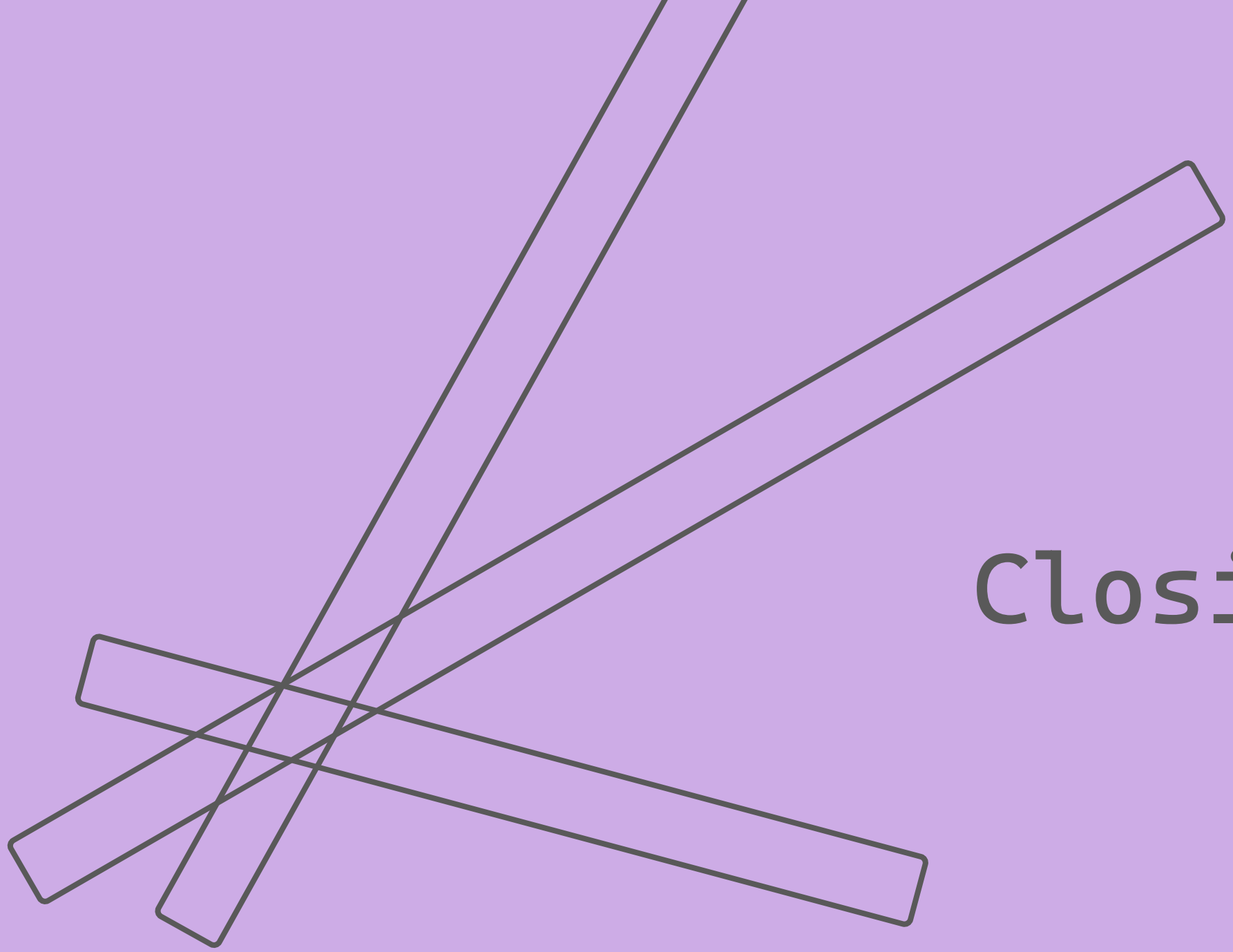
- Broadly, should only focus on relevant defense layers

- Registry persistence → EDR, SIEM
- Kerberoasting → Network, UEBA
- Phishing emails → Mail gateway

Results

2025 Outcomes

- Used on purple projects throughout 2025 (~200) as SOP
- Saw many failings with endpoint controls & custom rules
- Examples:
  - Volume Shadow Copy bulk deletion
  - Registry credential dumping
  - Common persistence mechanisms (e.g. scheduled tasks)



Closing

Closing

- Many tools rely on unreliable data, bad criteria
- Atomic testing focused on behaviors can help
- Push yourself + vendors to improve

Closing

- Slides
  github.com/SecurityRiskAdvisors/public-assets

- ALLCAPS
  github.com/SecurityRiskAdvisors/allcaps

- Me
  @2xxeformyshirt
  2xxe.com

Questions?